

Watchdog

Monitoring Threema Client Integrity

27th of February 2025

Introduction *Supply Chain Trust*

Signal Private Messenger

Signal Foundation
In-app purchases

4.5★
2.64M reviews

100M+
Downloads

PEGI 3

Install

Share

Add to wishlist

This app is available for your device



App support ▾

About this app →

Signal is a messaging app with privacy at its core. It is free and easy to use, with strong end-to-end encryption that keeps your communication completely private.

• Send texts, voice messages, photos, videos, GIFs, and files for free. Signal uses your phone's data connection, so you avoid SMS and MMS fees....

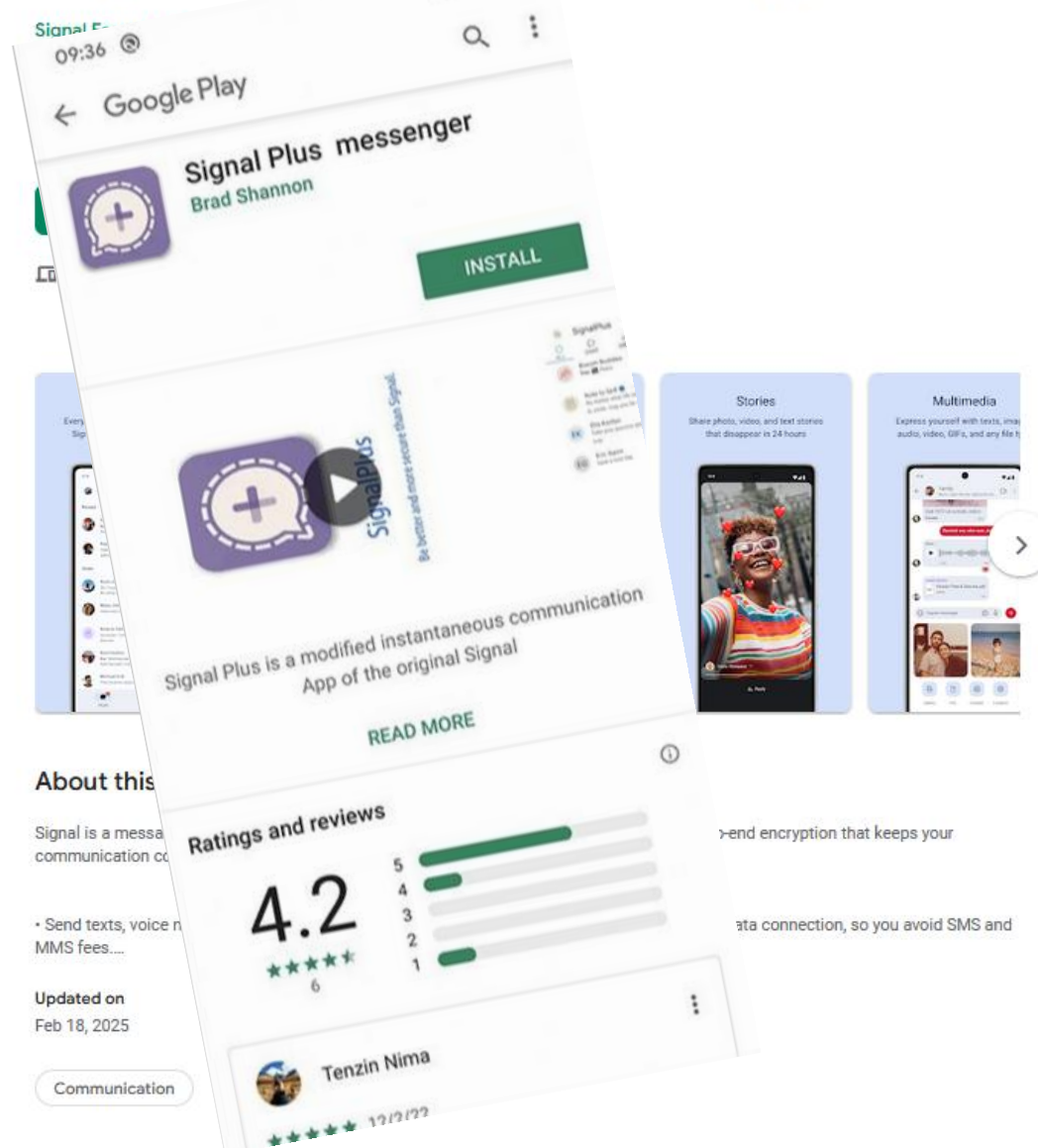
Updated on
Feb 18, 2025

Communication



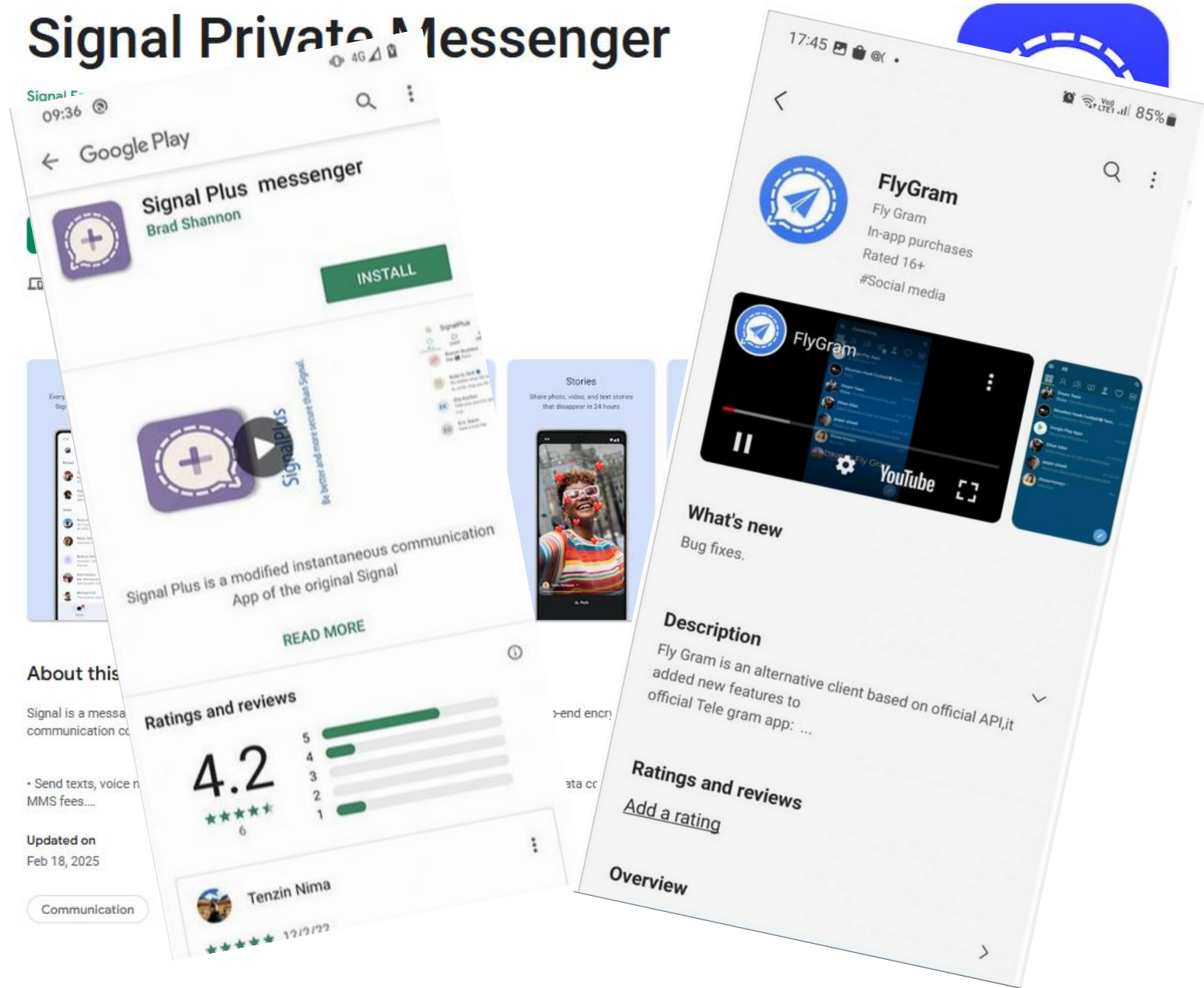
Introduction *Supply Chain Trust*

Signal Private Messenger



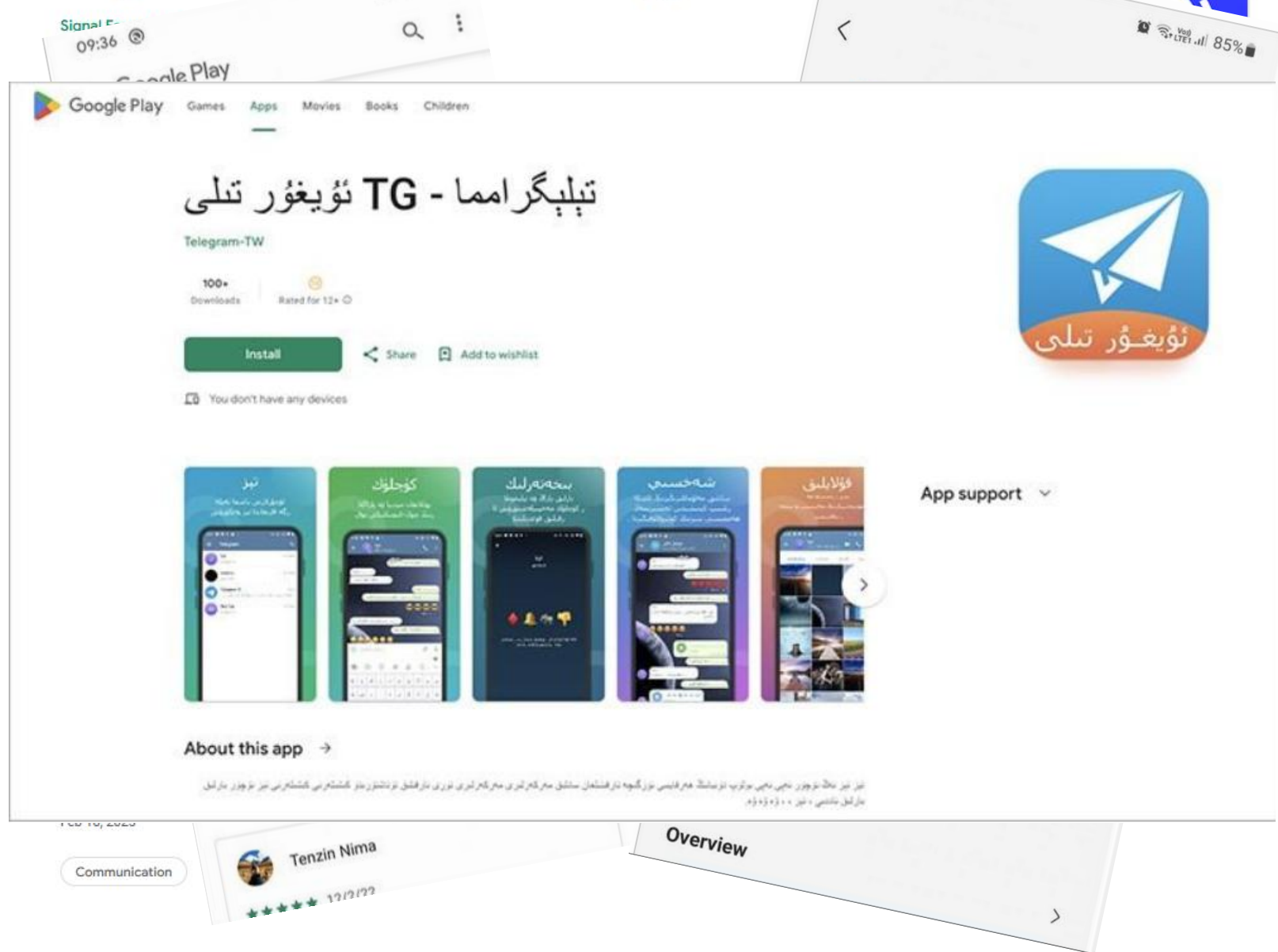
Introduction *Supply Chain Trust*

Signal Private Messenger



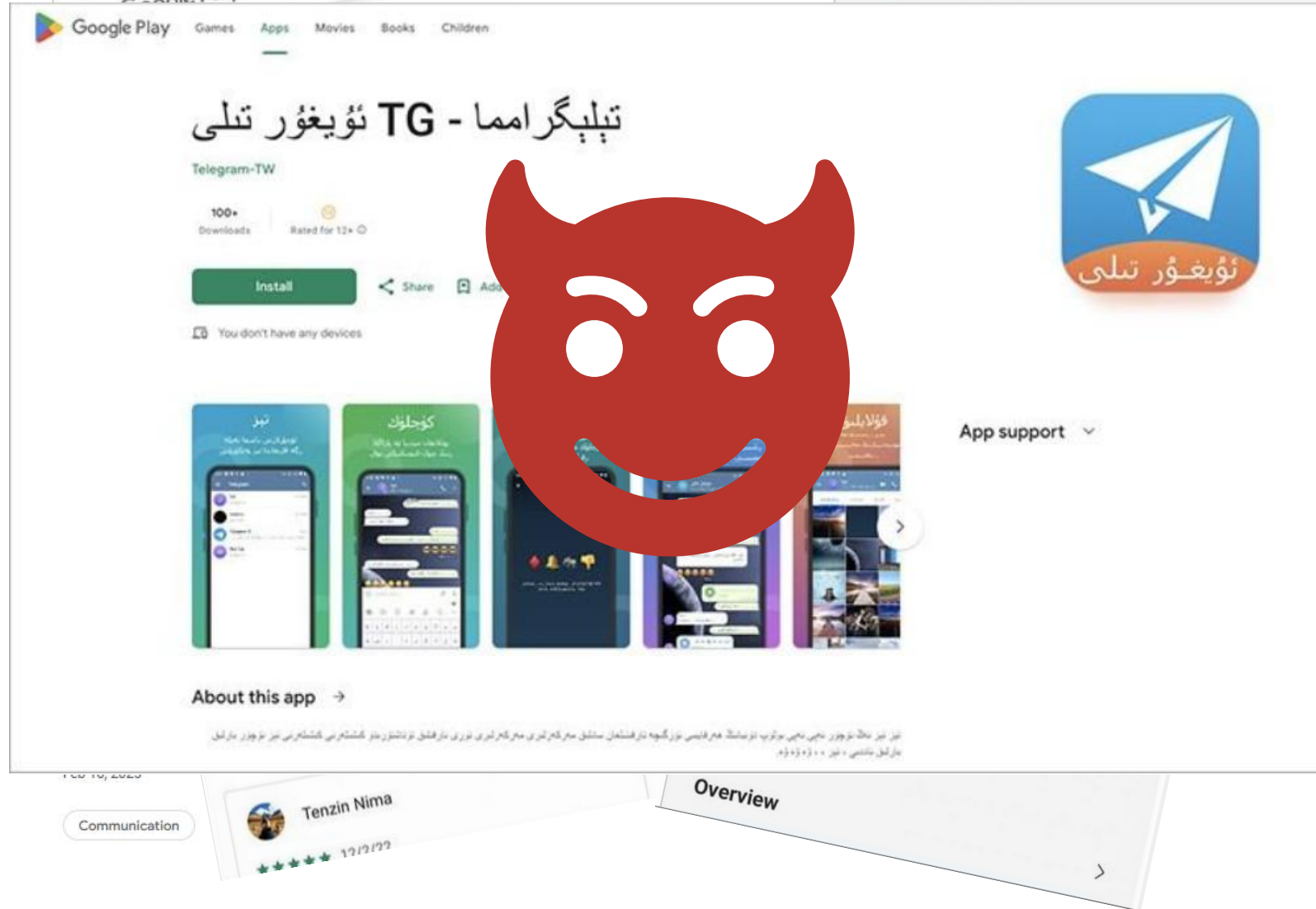
Introduction Supply Chain Trust

Signal Private Messenger



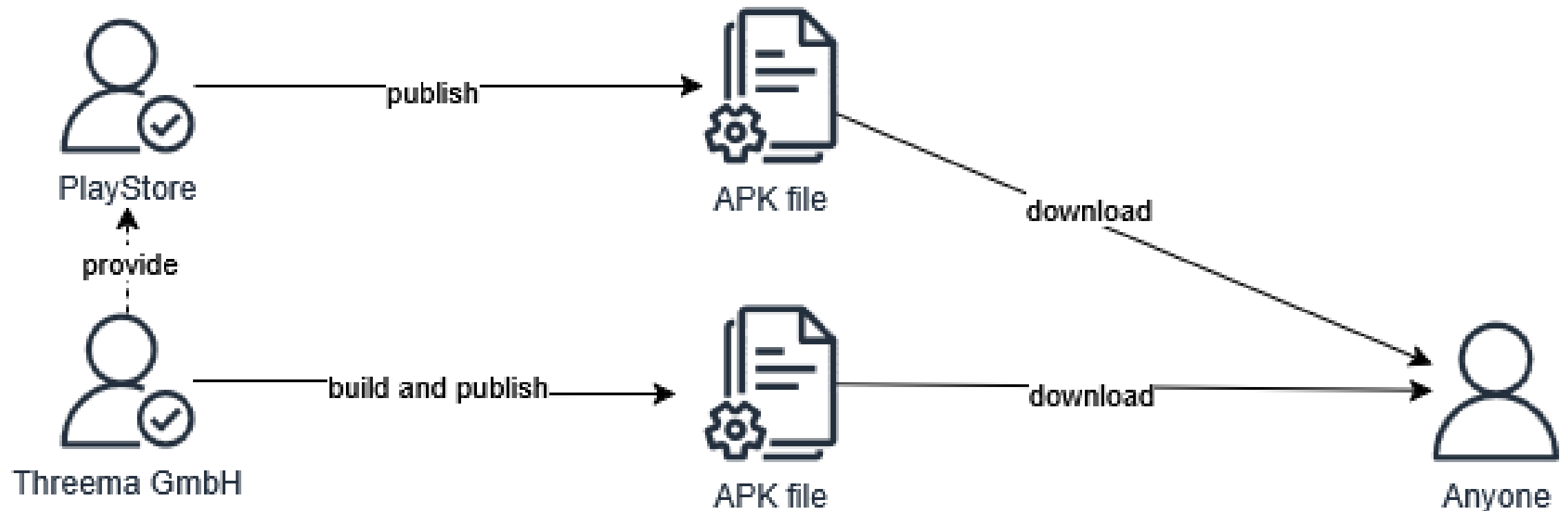
Introduction Supply Chain Trust

Signal Private Messenger



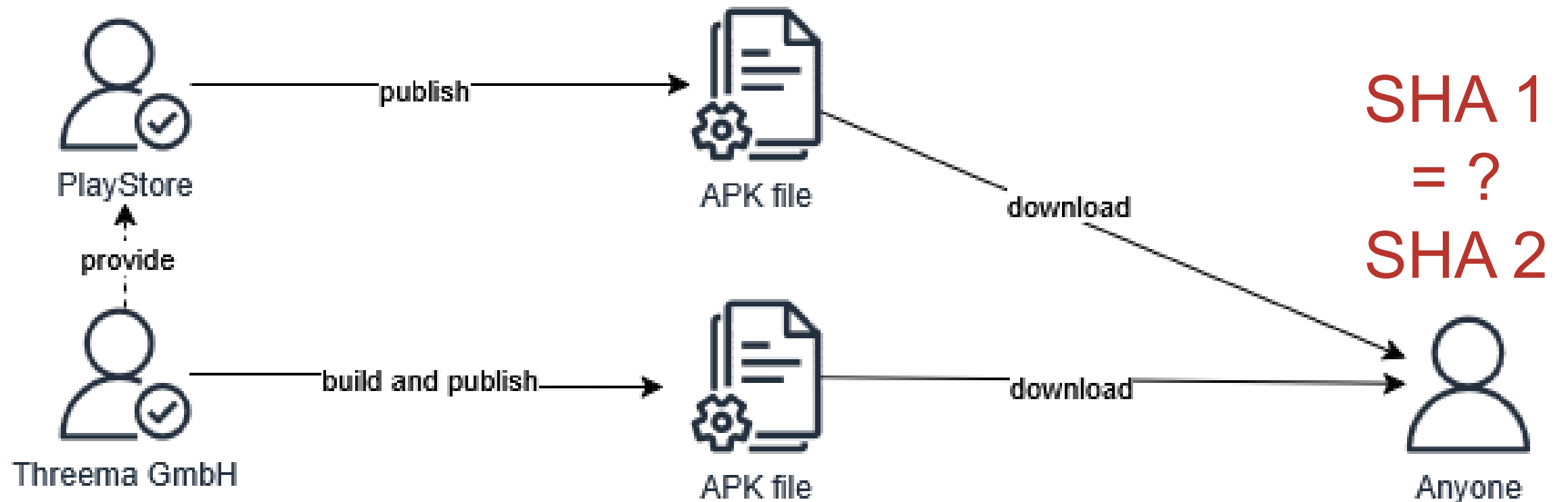
Introduction

Integrity



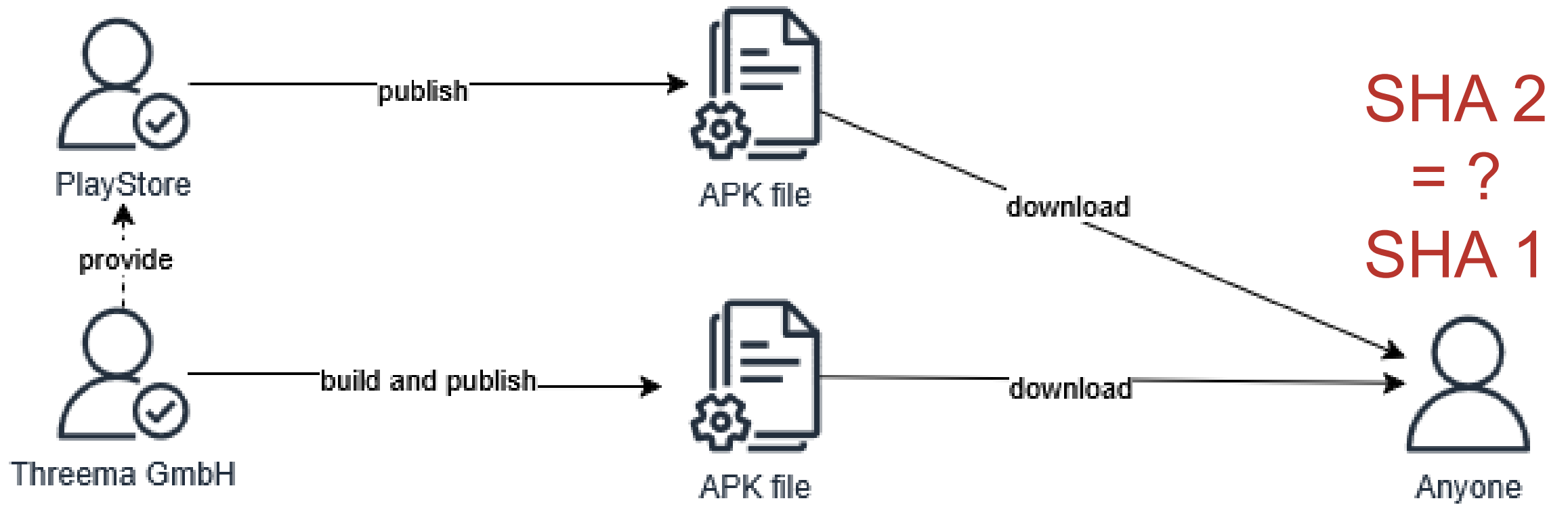
Introduction

Integrity



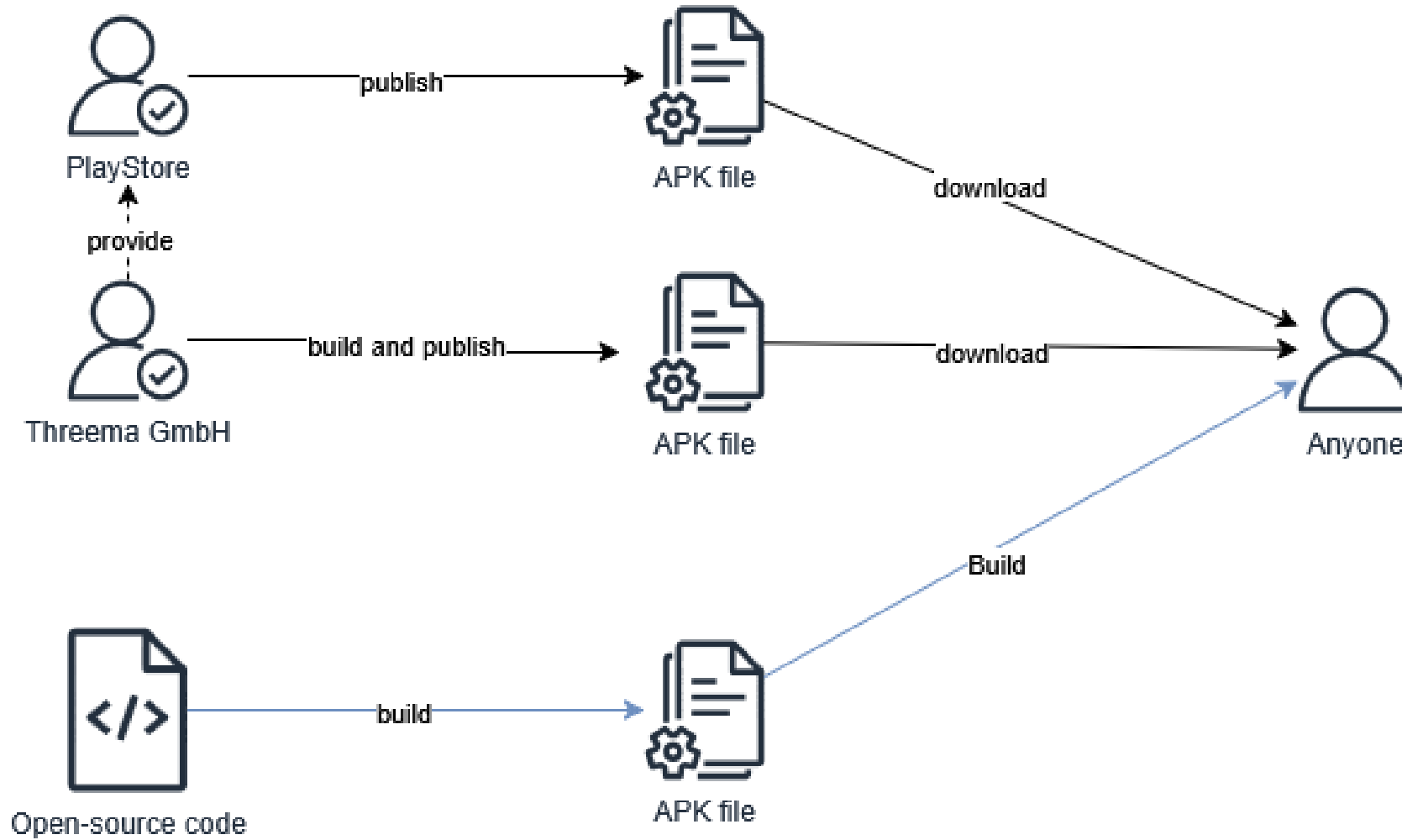
Introduction

Integrity



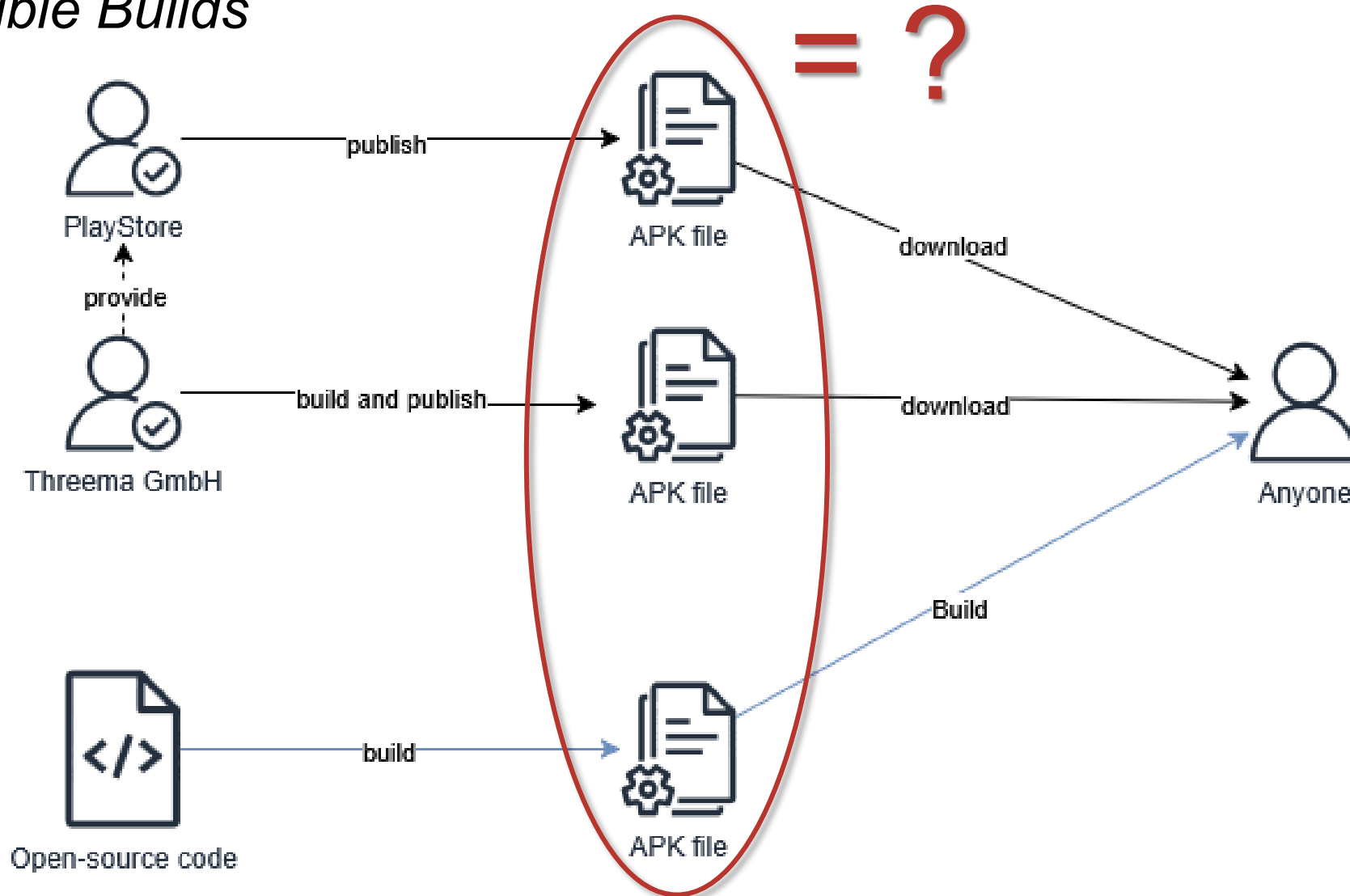
Introduction

Reproducible Builds



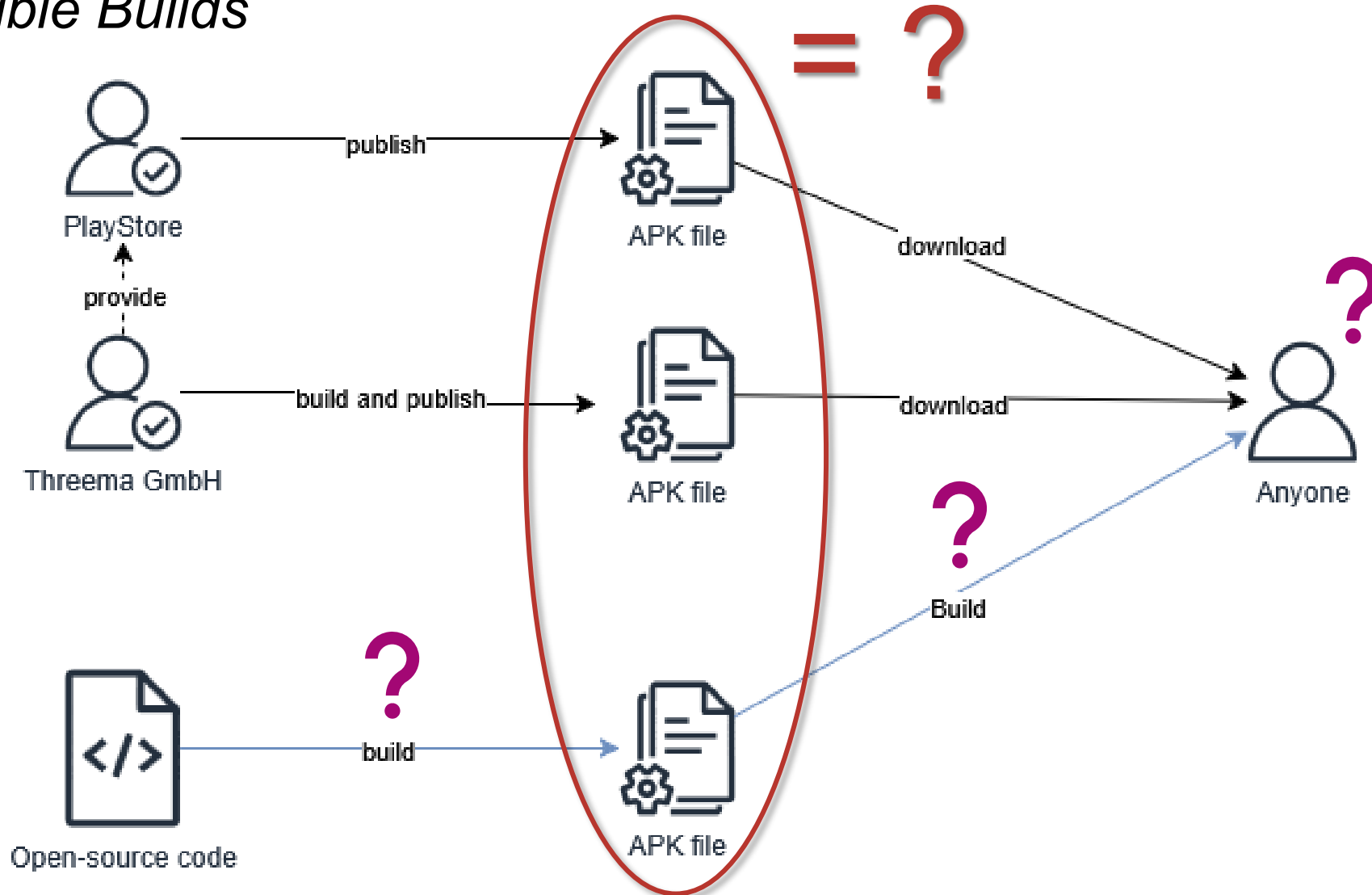
Introduction

Reproducible Builds



Introduction

Reproducible Builds



Introduction

Watchdog

chdog

	Application ?	Version ?	Architecture ?	Version Code ?	Reproducibility ?	Checksum ?	Build date ?	APK source ?	Source code ?
	 Threema Libre	5.8.1	universal	1050	Success	627f30e2 	2/22/2025		
	 Threema Libre	5.8.0	universal	1043	Success	99d680d7 	1/27/2025		
	 Threema Libre	5.7.0	universal	1033	Failure	069d5fae 	2/2/2025		
	 Threema Libre	5.6.1	universal	1013	Success	84ab16e3 	11/21/2024		
	 Threema Libre	5.6.0	universal	1012	Success	2aa99450 	11/12/2024		
	 Threema Libre	5.5.1	universal	998	Success	7a7050dc 	9/30/2024		

Introduction

Watchdog

Instructions to extract your APK

▼

Upload APK

ch.threema.app.libre-5.7.0l(1).apk

Your APK matches the source APK from the below log.
Be careful, we were not able to reproduce it succesfully!



	Application	Version	Architecture	Version Code	Reproducibility	Checksum	Build date	APK source	Source code	C
	?	?	?	?	?	?	?	?	?	
	Threema Libre	5.7.0	universal	1033	Failure	069d5fae	2/2/2025			b2

Contents

-
1. Introduction
 2. Problem Statement
 3. Desired Properties
 4. Assumptions
 5. Attacker Model
 6. Background
 7. System Design
 8. Analysis
 9. Evaluation
 10. Conclusion
-

Problem Statement



Source Guarantee

Checksums alone do not guarantee an application was built from a given source code.



User Barriers

Users will not perform integrity checks if they are complicated.



Centralization

Distributor-controlled checksums and monitors create single points of failure.

How can we make integrity checks both more robust and more accessible ?

Desired Properties



Reproducible Build Monitoring System



Usability

Intuitive browsing
Effortless verification
Reduced false positives



Decentralization

Independent verification by third-parties
Easy set up for scalability



Transparency

Fully auditable rebuild and logging process to strengthen trust.



Automation

Minimal human intervention for efficiency.

Assumptions



Reproducible Build Support

Apps need to be designed for reproducibility
Security VS Randomness
Growing acceptance



Reproducibility Consistency

Security-critical VS Accident
Maintain trust

Attacker Model

Motivating Attacks



INSIDER ATTACK



**BUILD-TIME
COMPROMISE**



**MALICIOUS
DISTRIBUTOR**

Background



Signal

Background



Signal

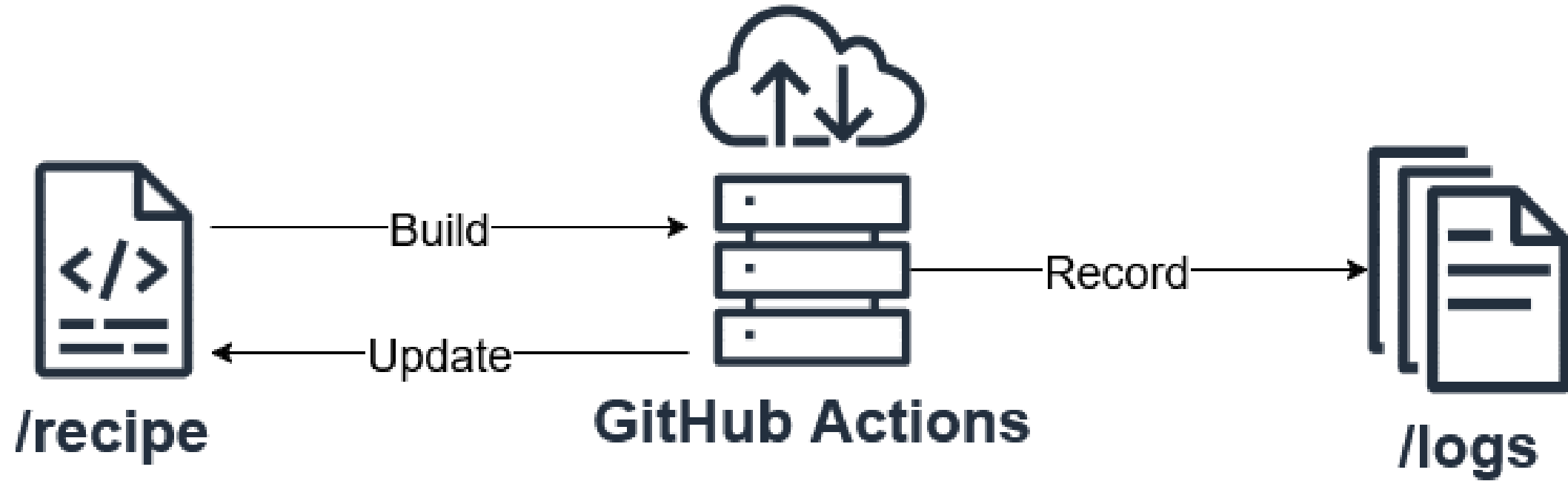
Background



Threema

Background

Rbtlog



Background

Rbtlog

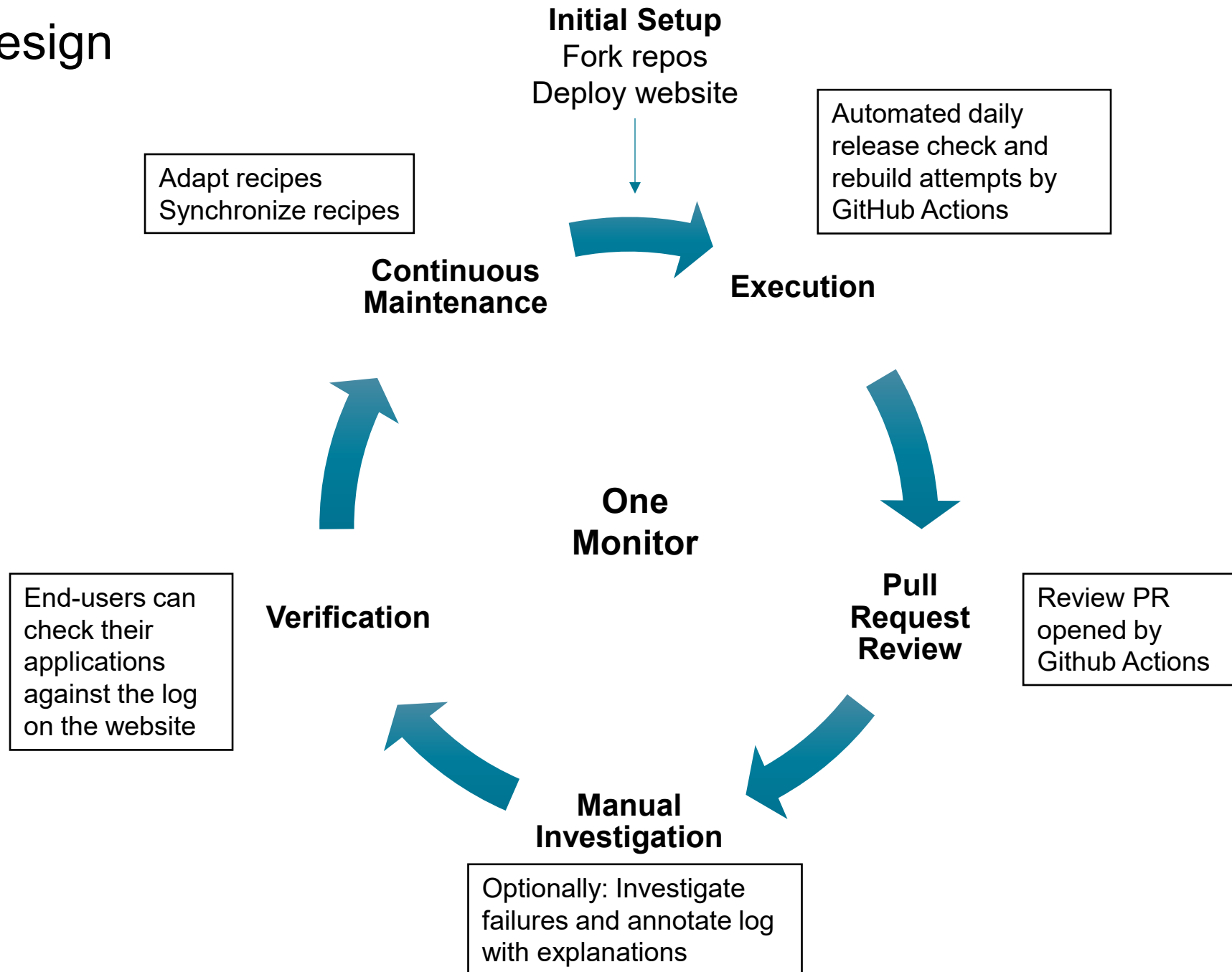
```
repository: https://github.com/threema-ch/threema-a
updates: tags:([\d.]+)
versions:
- tag: 5.2.3
  apks:
  - apk_pattern: ch\.threema\.app\.libre-([\d.]
    apk_url: https://releases.threema.ch/fdroid
    build:
      - sed -r '/abi \{/,/}/ s/enable true/enab
      - ./gradlew assembleLibreRelease
      - mv app/build/outputs/apk/libre/release/
    build_home_dir: /build
    build_repo_dir: /build/repo
    build_user: build
    provisioning:
      android_home: /opt/sdk
      build_tools:
      cmake:
      cmdline_tools:
        version: '12.0'
        url: https://dl.google.com/android/repo
        sha256: 2d2d50857e4eb553af5a6dc3ad507a1
      extra_packages: []
      image: debian:bookworm-slim
      jdk: openjdk-17-jdk-headless
      ndk:
      platform:
```

succeeded 3 days ago in 3h 7m 16s

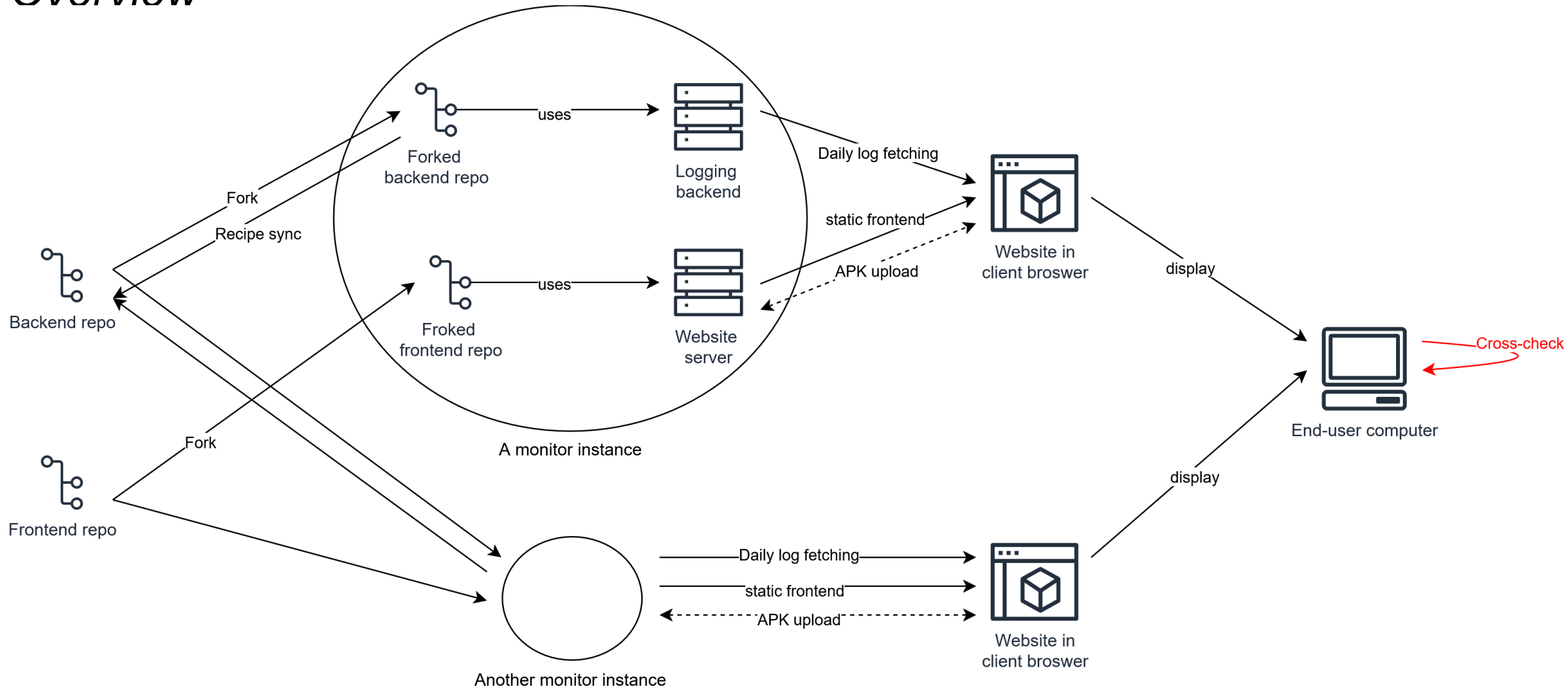
```
1 Run mkdir apks  
12 Updating 'ch.threema.app.libre'...  
13 Building ['ch.threema.app.libre:5.7.0', 'ch.threema.app.libre']  
14 Building 'ch.threema.app.libre:5.7.0'...  
15 Downloading 'https://releases.threema.ch/fdroid/repo/ch.threema.app/libre-5.7.0.apk'...  
16 Running 'podman pull -- ubuntu:noble'  
17 Running 'podman run --rm --volume /tmp/tmpjz8s7fi4/outputs:/out:  
    ANDROID_HOME=/opt/sdk --env APP_REPOSITORY=https://github.com/threema-libre/android-app-fdroid-repository:  
    APP_COMMIT=ca14fac988895dd037add1750976cf4bba358cde --env BUILD_REPO_DIR=/build/repo --env BUILD_DIRS="" --env PROVISIONING_CMDLINE_TOOLS_VERSION=12.0 --env PROVISIONING_CMDLINE_TOOLS_SHA256=2d2d50857e4eb553af5a6dc3ad1f0beccac331e64a3c09e06e2010192d0bb --env PROVISIONING_EXTRA_PACKAGES=build-essential,protohub-compile-env PROVISIONING_NDK=25.2.9519653 --env PROVISIONING_PLATFORM=x86_64-linux-proton --env PROVISIONING_TOOLS=/usr/bin/curl --env VERIFY_GIT=yes --env VERIFY_GRADLE_TIMEOUT=10m /scripts/provision-root.sh && cd /build && timeout 20m su build /scripts/build.sh'...  
  
18 --- BEGIN BUILD LOG ---  
19 RUN COMMAND podman pull -- ubuntu:noble  
20 Resolved "ubuntu" as an alias (/etc/containersregistries.conf)  
21 Trying to pull docker.io/library/ubuntu:noble...
```

```
"tags": {  
  "5.2.3": [  
    {  
      "recipe": {  
        "provisioning": {  
          "version": "12.0",  
          "url": "https://dl.google.com/android/repository  
          "sha256": "2d2d50857e4eb553af5a6dc3ad507a17adf4  
        },  
        "extra_packages": [],  
        "image": "debian:bookworm-slim",  
        "jdk": "openjdk-17-jdk-headless",  
        "ndk": null,  
        "platform": null, obfusc, 12 months ago • U  
        "platform_tools": null,  
        "tools": null  
      }  
    },  
    "timestamp": 1708120383,  
    "reproducible": true,  
    "error": null,  
    "build_log": "RUN COMMAND podman pull -- debian:bookw  
d/shortnames.conf)\nTrying to pull docker.io/library/  
sha256:e1caac4eb9d2ec24aa3618e5992208321a92492aef5fef  
sha256:e1caac4eb9d2ec24aa3618e5992208321a92492aef5fef  
sha256:711de258f0e0a9171cb8908c86676f859d2cc74cbe738c  
signatures\n711de258f0e0a9171cb8908c86676f859d2cc74cb  
tmp15_cz5c8/outputs:/outputs --volume /tmp/tmp15_cz5c8
```

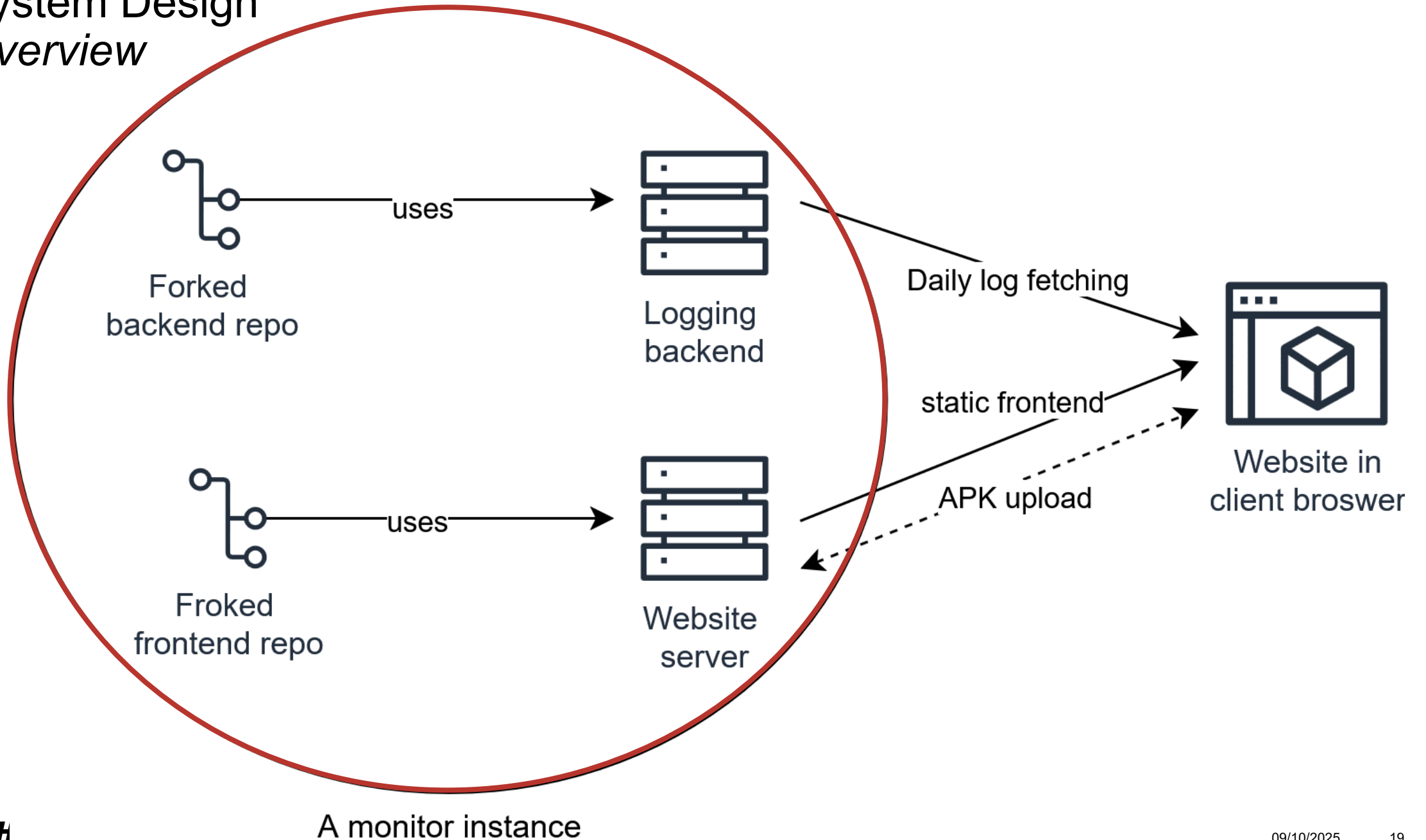
System Design Overview



System Design Overview



System Design Overview



Dynamic download link search



ZIP archives processing



Optional notes field for build failure contextualization



Threema OnPrem and Work support

System Design

Frontend

What is a Reproducible Build?

Reproducible Builds are a set of software development practices that create an independently-verifiable path from source code to the binary code used by computers. This means that anyone can reproduce the build process and get the same results. Reproducible Builds ensure that the software you trust is both safe and verifiable. They do this by verifying that the binaries that you download match the original, untampered source code. For security-related tools, like secure messaging apps, this means high confidence that your data and communications are protected against hidden backdoors or vulnerabilities.

[Learn more about Reproducible Builds](#)

Check your application

An APK (Android Package) is the file format used to distribute and install applications on Android devices. If you have an application installed on your device, you can extract its APK and upload it here to check if it matches the APKs in any of our reproduction attempts. This can help you assess the authenticity of the application you have installed.

Instructions to extract your APK

Upload APK some-signak (18).apk

Reproducible Build Log

This table shows the logs of the reproduction attempts made by [Valentine14th/rbtlog](#). For increased confidence, cross-check your results with other verifiers!

Filter the logs by using the options below:

Applications Versions Architectures Reproducibility

Application	Version	Architecture	Version Code	Reproducibility	Checksum	Build date	APK source	Source code
Threema Libre	5.8.0	universal	1043	Success	99d680d7	1/27/2025		
Threema Libre	5.7.0	universal	1033	Failure	069d5fae	2/2/2025		
Threema Work	5.8.0	universal	1043	Success	6cc6f746	1/30/2025		

System Design

Frontend Components

What is a Reproducible Build?

Reproducible Builds are a set of software development practices that create an independently-verifiable path from source code to the binary code used by computers. This means that anyone can reproduce the build process and get the same results.

Reproducible Builds ensure that the software you trust is both safe and verifiable. They do this by verifying that the binaries that you download match the original, untampered source code. For security-related tools, like secure messaging apps, this means high confidence that your data and communications are protected against hidden backdoors or vulnerabilities.

[Learn more about Reproducible Builds](#)

System Design

Frontend Components

Reproducible Build Log

This table shows the logs of the reproduction attempts made by [Valentine14th/rbtlog](#).
For increased confidence, cross-check your results with other verifiers!

Filter the logs by using the options below:

Applications 

Versions 5.7.0, 5.8.0 

Architectures universal 

Reproducibility 



The commit officially tagged as 5.7.0 on the Threema repo is missing patches/ sources which causes re-builds to crash. This build is based on the next fix commit adding those files. The libre version is not reproducible under that fix commit, however, the onPrem and work version are.

Application	Version	Architecture	Version Code	Reproducibility	Checksum	Build date	APK source	Source code	
									
 Threema Libre	5.8.0	universal	1043	Success	99d680d7 	1/27/2025			2
  Threema Libre	5.7.0	universal	1033	Failure	069d5fae 	2/2/2025			b
 Threema Work	5.8.0	universal	1043	Success	6cc6f746 	1/30/2025			2

System Design

Frontend Components

[Learn more about Reproducible Builds](#)

Check your application

An APK (Android PackKage) is the file format used to distribute and install applications on Android devices.

If you have an application installed on your device, you can extract its APK and upload it here to check if it matches the APKs in any of our reproduction attempts. This can help you assess the authenticity of the application you have installed.

Instructions to extract your APK

Upload APK

Reproducible Build Log

This table shows the logs of the reproduction attempts made by [Valentine14th/rbtlog](#).
For increased confidence, cross-check your results with other verifiers!

Filter the logs by using the options below:

Usability

+

-

Clear
logging

Simple
verification

Easy
mirroring

Cross-
checking

Scalability

+

-

Become
monitor easily

Flexible
backend

Free-tier
limitation

Security

+

-

Containerized
runs

Transparency

Cross-
checking

Misbehaving
monitors

Cloud
environments

Evaluation

Version	Release Detection	Dynamic URL Finding	Reproducibility	Automatic Reproducibility
5.7.0	Success	Success	some only (OnPrem, Work)	Failure
5.8.0	Success	Success	all (OnPrem, Work, Libre)	Success

Table 7.1: Automatic reproducibility check results for versions 5.7.0 and 5.8.0 of *Threema*.



Problems in consistency

- **Watchdog issue:** Environment changes
- **Developer issue:** Incorrectly tagged release

Conclusion

Key Findings

- Easy and robust integrity checks are possible
- Partial automation achievable
- Third-party trust model is possible
- There is broader adoption potential

Challenges

- Infrastructure and developer commitment is needed
- Human-in-the-loop is still essential
- Ecosystem adoption is critical

Q&A

Watchdog: Monitoring Threema Client Integrity

<https://watchdog-coral.vercel.app/>

Future Work

- **Usability Studies**
- **Monitor Registry & Aggregation**
- **Enhanced APK Comparison**
- **Backend Automation Improvements**
- **Advanced Failure Analysis**
- **Expanded Application Support**